Network Security

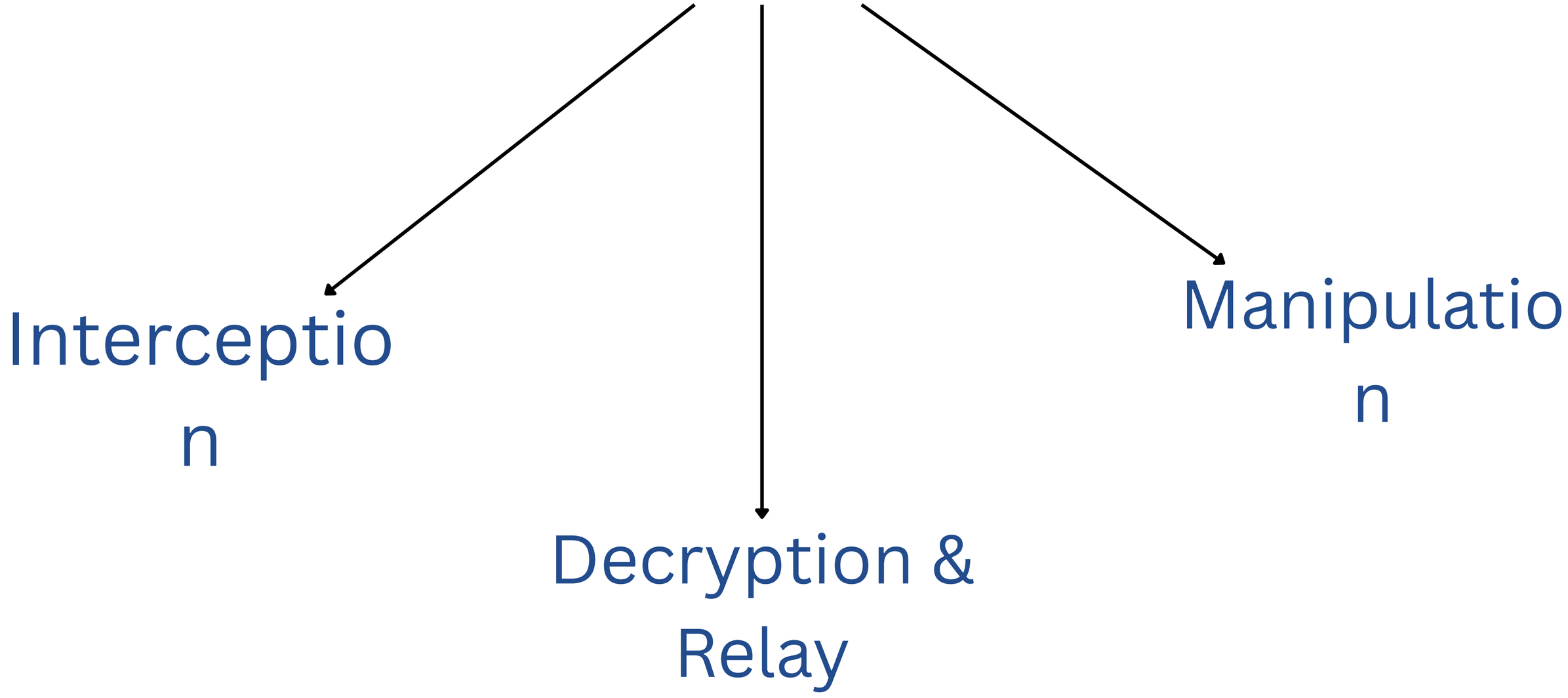
Group 02

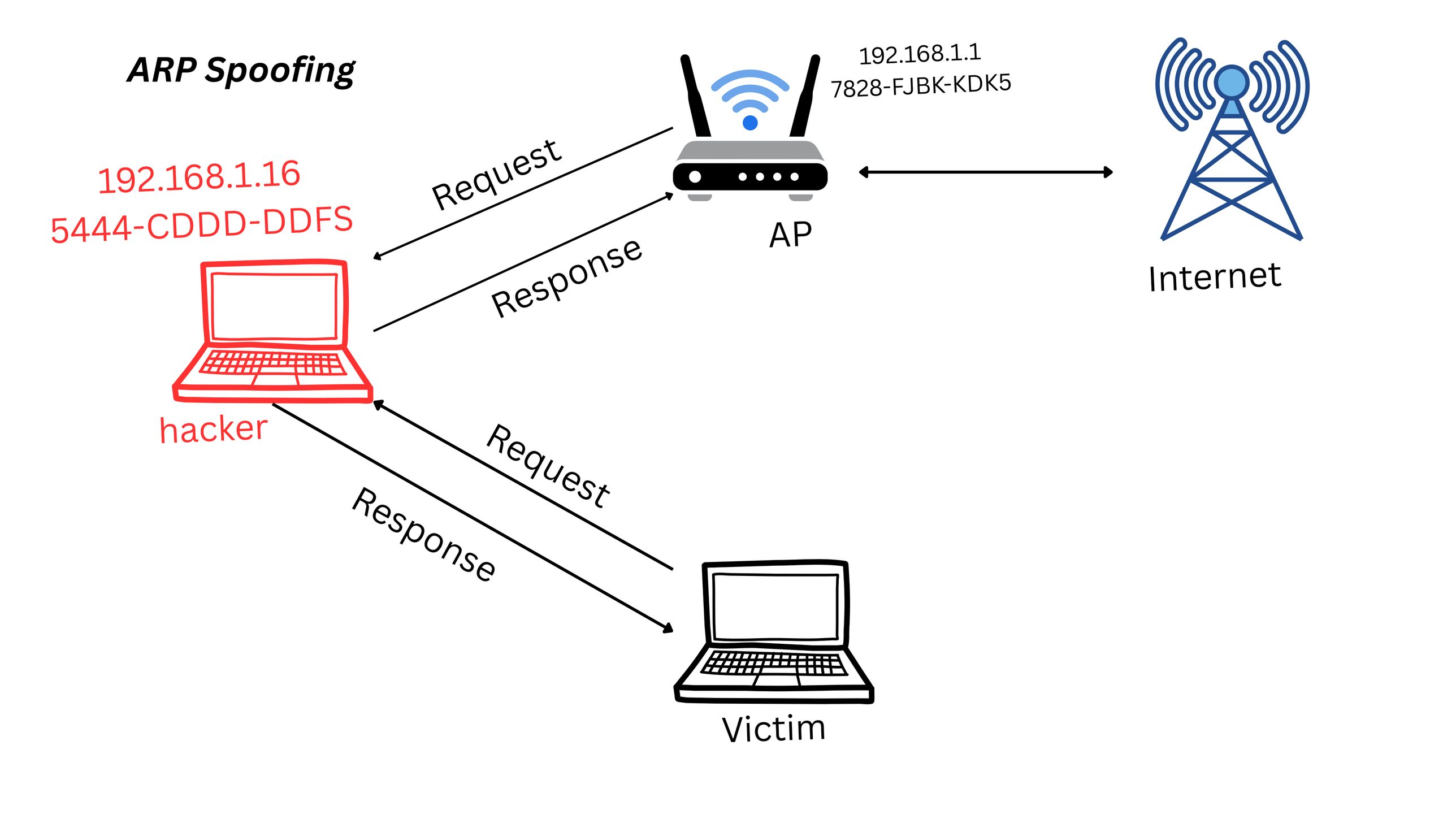
Man-in-the-Middle Attack

- SOK Kimheng
- TEK Chansetha

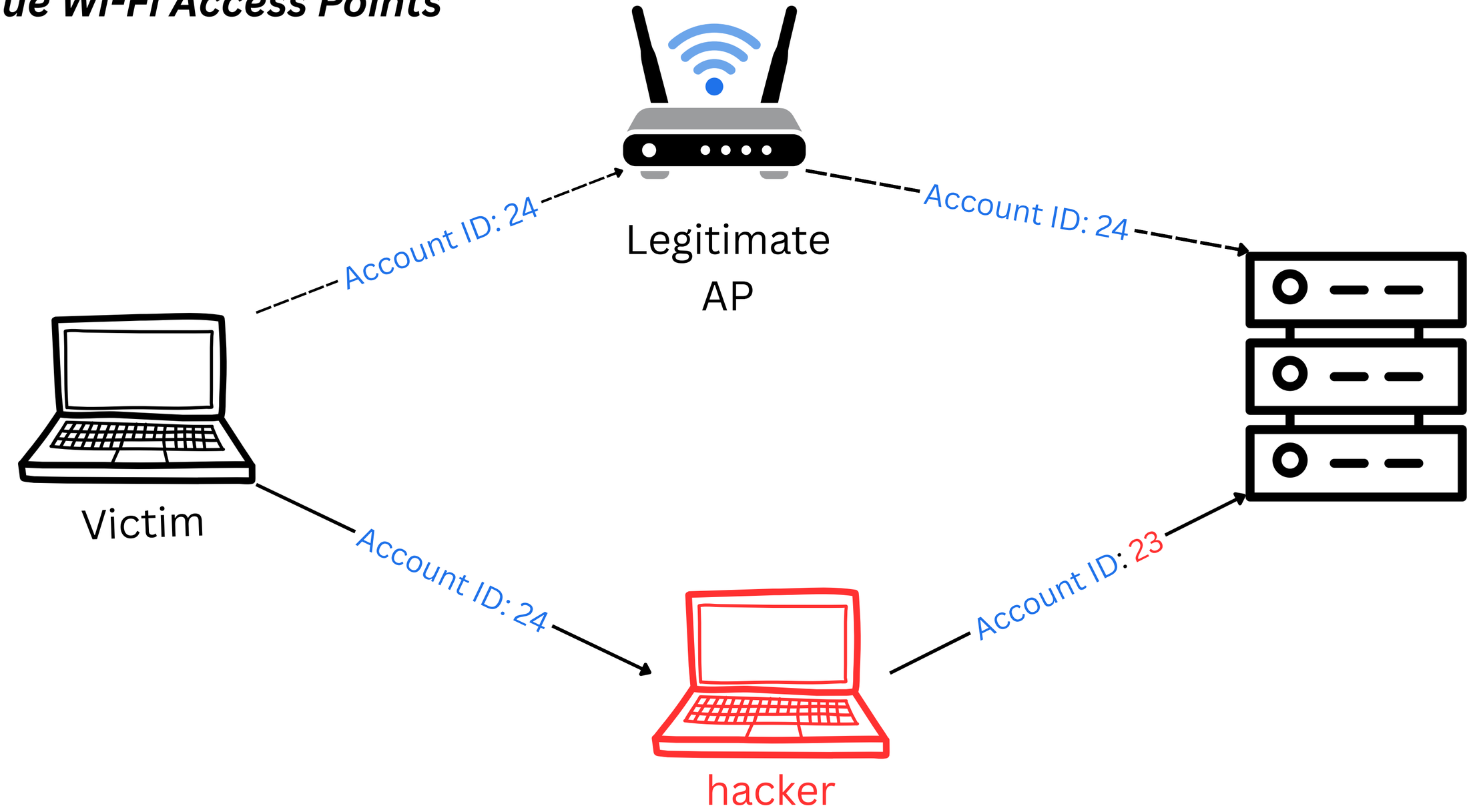
Lecturer: M. ANG Ousa

Man-in-the-Middle Attack

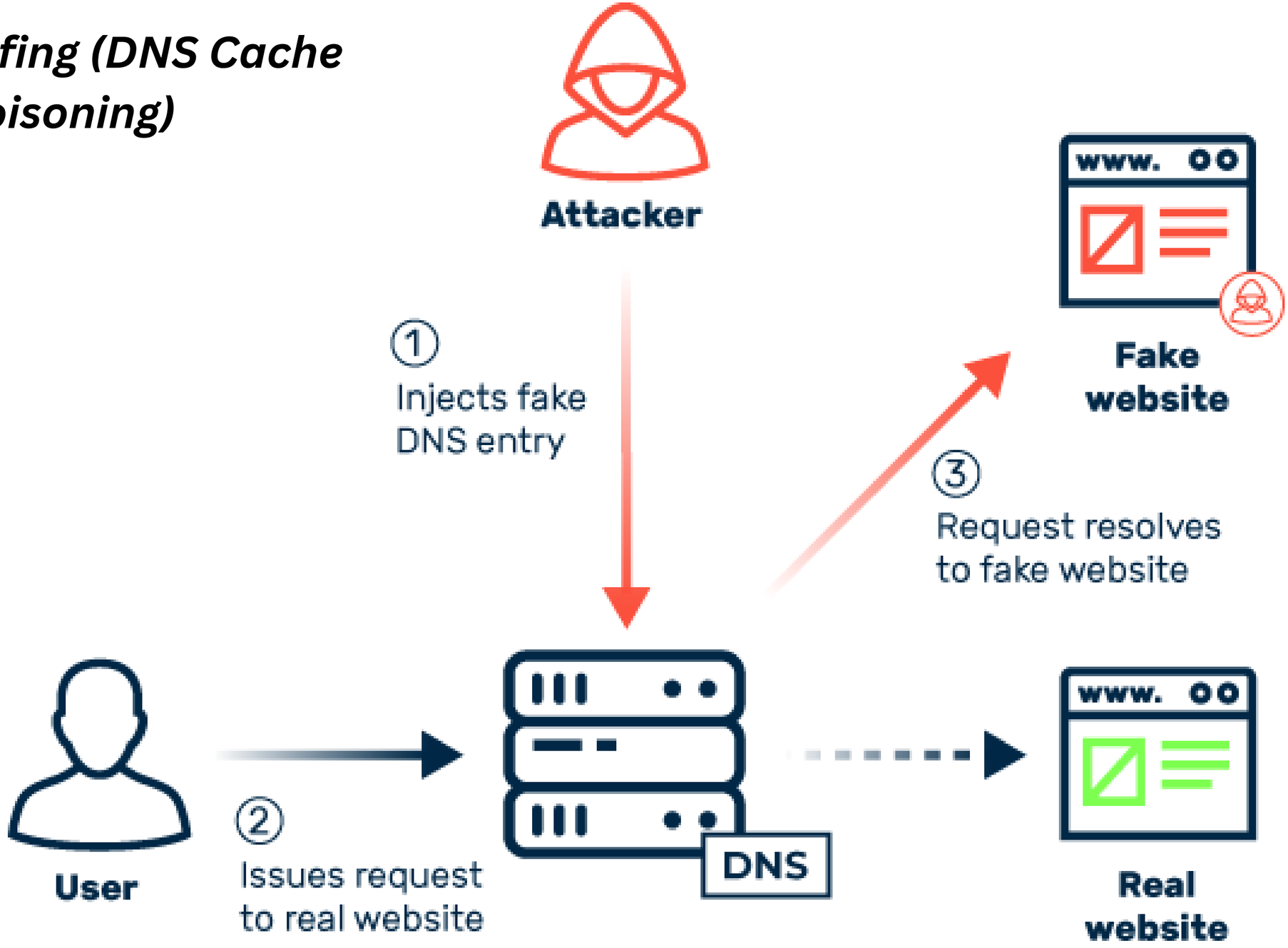



ARP Spoofing
192.168.1.16
5444-CDDD-DDFS
hacker
Request
Response
192.168.1.1
7828-FJBK-KDK5
AP
Internet
Request
Response
Victim

Rogue Wi-Fi Access Points

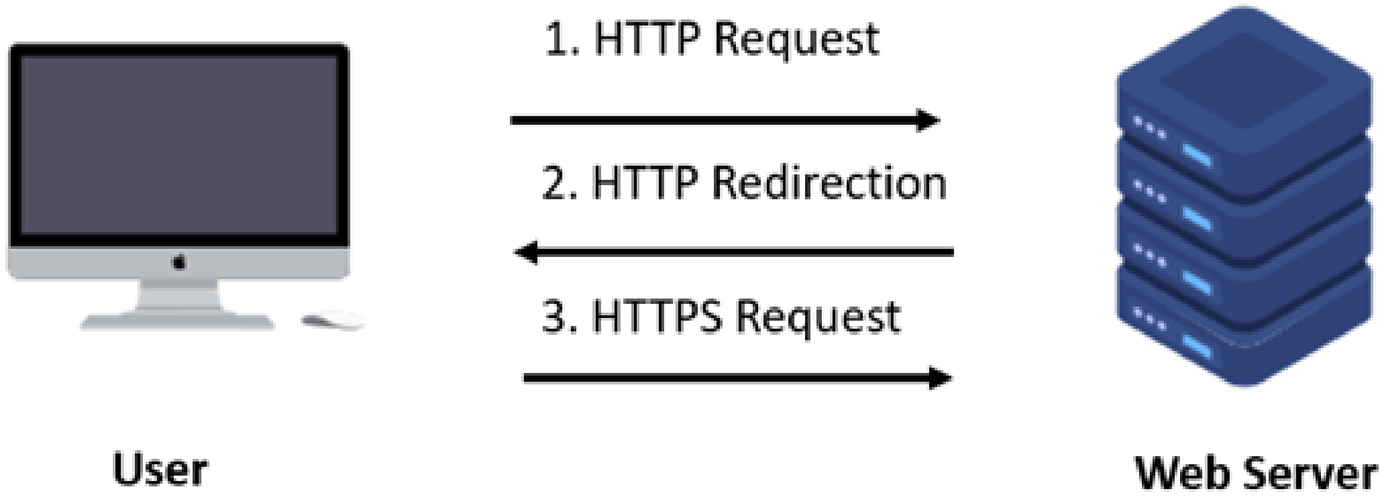


DNS Spoofing (DNS Cache Poisoning)



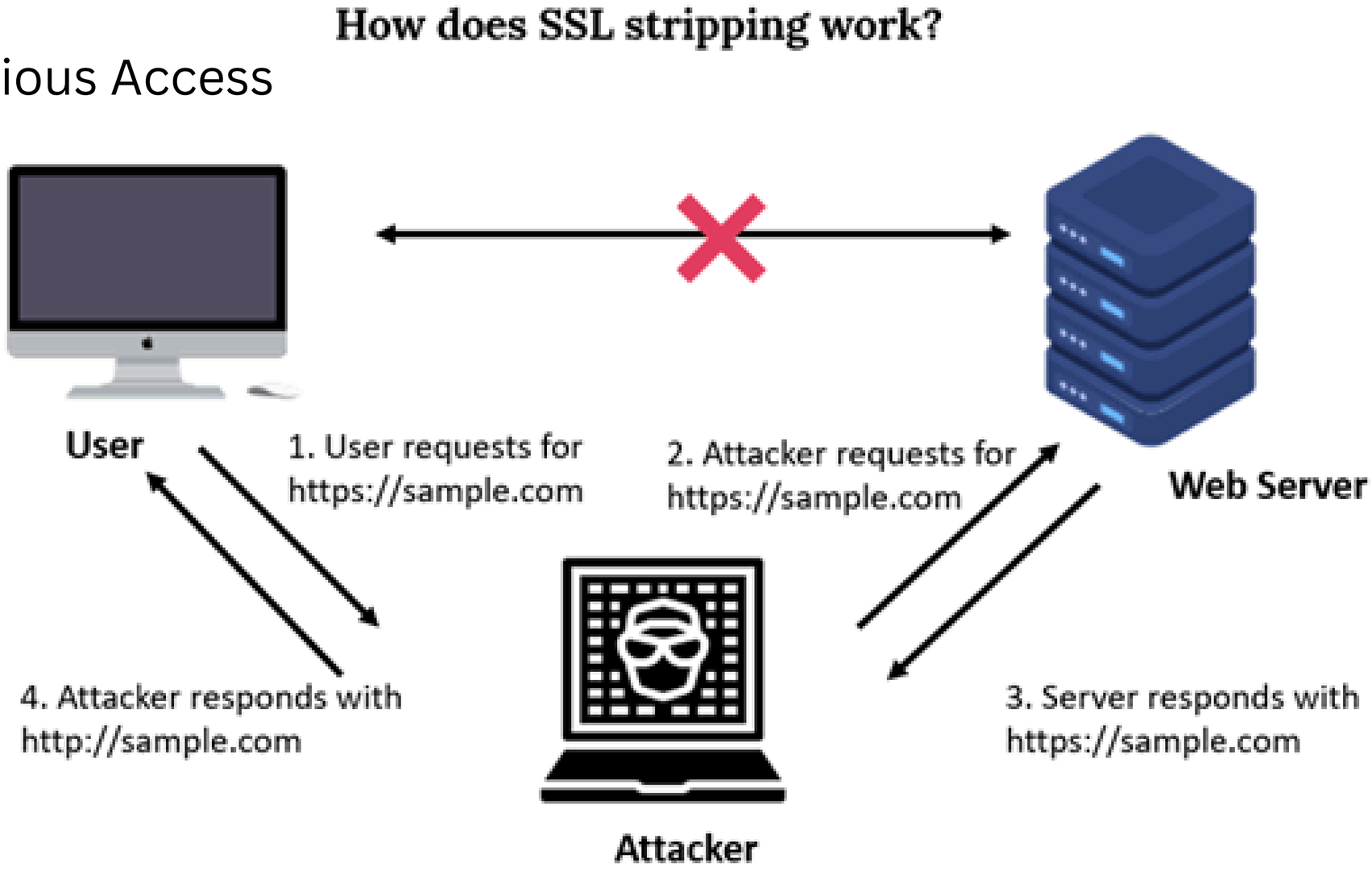
SSL/TLS Stripping

Normal Access

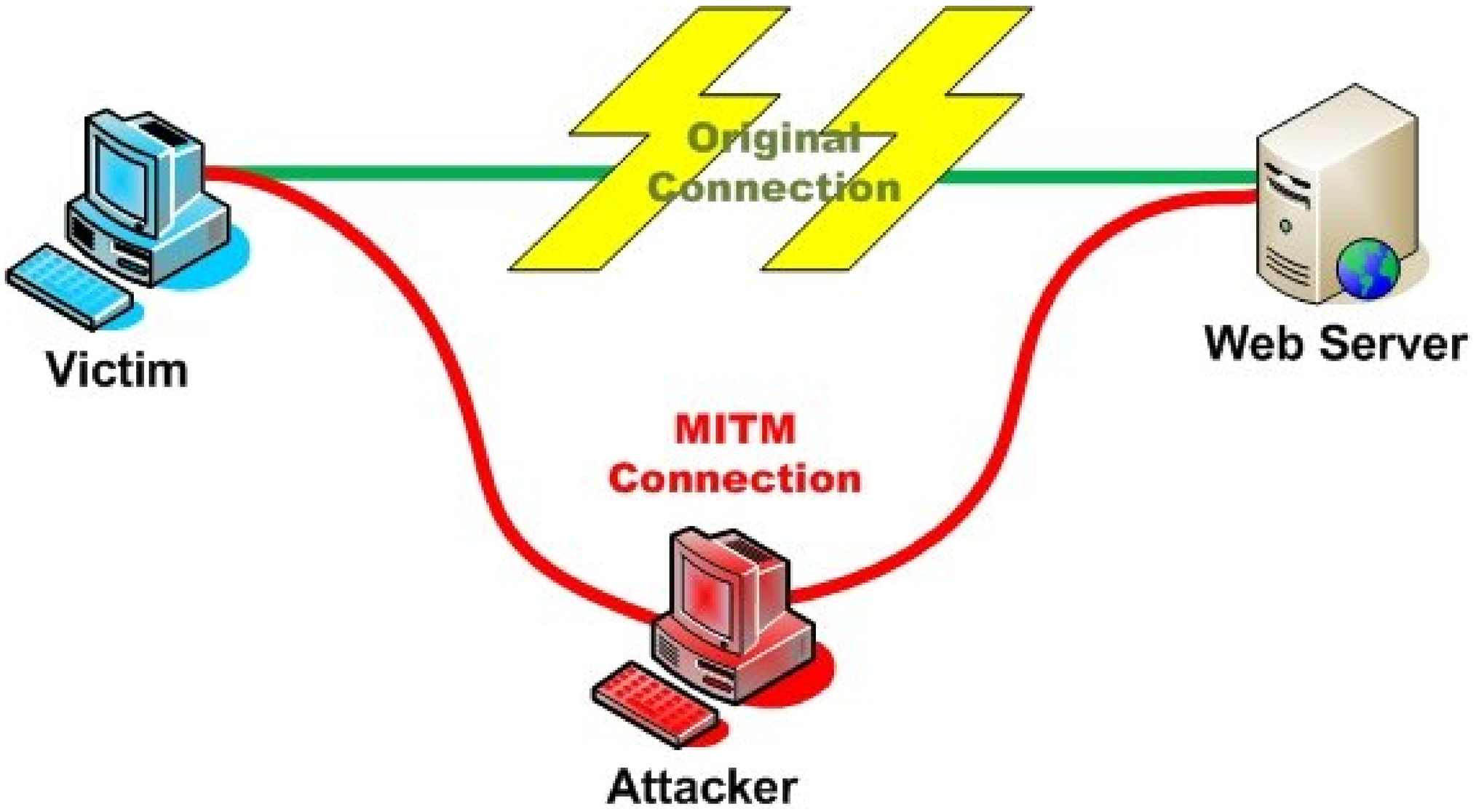


SSL/TLS Stripping

Malicious Access



HTTPS Spoofing



The 2011 DigiNotar

Netherlands and Iran

What happened

The attack

Attackers breached the DigiNotar certificate authority and issued fraudulent certificates, including one for *.google.com.

The interception

Traffic was redirected so browsers saw a trusted certificate while the attacker read Gmail sessions. Around 300,000 users, mostly in Iran, were exposed.

The Outcome

Browsers removed trust in DigiNotar and the company went bankrupt within months.

Root Causes and Lessons

Patching

The Struts patch was available in March 2017 but never applied.

Segmentation

Weak segmentation and plaintext credentials let attackers move freely.

Visibility

An expired certificate left outbound traffic uninspected for months.

Takeaway: a basic hygiene and visibility failure, not an advanced technique.

Prevention Strategies

For Users:

- Avoid executing sensitive transactions (like banking or shopping) on unsecured public Wi-Fi networks.
- Always verify that the website URL begins with HTTPS and displays a valid lock icon.
- Utilize a Virtual Private Network (VPN) to encrypt all network traffic leaving your device.
- Deploy robust Multi-Factor Authentication (MFA). Note that traditional MITM attacks cannot easily bypass MFA, though specialized evolutions like Adversary-in-the-Middle (AITM) use reverse-proxies to target session cookies directly.

For Organizations:

- Enforce comprehensive, site-wide encryption protocols via SSL/TLS.
- Implement HTTP Strict Transport Security (HSTS) policies to ensure browsers never fall back to insecure HTTP connections.

References:

- sosafe-awareness.com
- imperva.com
- cyberlaw.ccdcoe.org/wiki/DigiNotar_(2011)
- gemini.google.com